

Derivation of trust federation for collaborative business processes

Ji Hu

Published online: 3 November 2010
© Springer Science+Business Media, LLC 2010

Abstract Service Oriented Architecture (SOA) is considered to be an important enabler of Internet of Services. By adopting SOA in development, business services can be offered, mediated, and traded as web services, so as to support agile and dynamic business collaborations on the Internet. Business collaboration is often implemented as cross-enterprise processes and involves more than one business entity which agrees to join the collaboration. To enable trustworthy and secure provision of services and service composition across enterprise boundaries, trust between business participants must be established, that is, user identities and access rights must be federated, to support business functions defined in the business processes. This paper proposes an approach which derives trust federation from formally described business process models, such as BPMN and WS-CDL processes, to automate security configuration of business collaborations. The result of the derivation is trust policies which identify trust relationships between business participants and can be enforced in enterprises' service runtimes with support of a policy deployment infrastructure.

Keywords Business processes · Trust · Security

1 Introduction

In traditional enterprise computing, applications and services are offered for their employees and internal systems to support complex business processes. Therefore, enterprise services are normally deployed and operated in enterprise boundaries, with limited connectivity to outside systems for

communications services such as VPN, E-Mail, and Web services. Internet of services as a new computing paradigm is focused on service-based business process executions between enterprises and their suppliers or customers (Heuser et al. 2008). Internet of services creates an eco-system where business services are offered, discovered, traded, and consumed on the Internet so as to support agile and dynamic business collaboration as well as value added services which are made up of services offered by various providers.

Service-oriented architecture (SOA) is a loosely coupling software architecture which makes services implemented and operated on heterogeneous platforms interoperable via common communication interfaces such as web services or REST (Fielding and Taylor 2002). By offering business functions as web services, we can break up enterprise boundaries and harmonize services of diverse development platforms. Business services can be made openly available and reusable for supporting collaborative business processes by service orchestration or service choreography.

Development of business processes mainly relies on model driven approach to leverage modeling technologies for defining generic or semi-generic business processes and then transforming the models into platform-dependent implementations. Model driven approach is considered to be an agile software development methodology due to its capability of translating business process definitions into executable implantations. Business process modeling languages such as BPMN (OMG 2008, 2009), BPEL (Alves et al. 2007), and WS-CDL (Kavantzaz et al. 2005) provide important instruments for describing business processes at design time. Business collaborations such as B2B e-commerce, supply chain management, and virtual organizations can be modeled by a number of modeling languages. E.g. BPEL provides abstract processes to describe public interactions of partners. BPMN supports both private and collaboration (global) processes. WS-CDL is a service

J. Hu (✉)
SAP Research Center Karlsruhe,
Vincenz-Priessnitz-Str. 1,
76131 Karlsruhe, Germany
e-mail: ji.hu@sap.com

choreography description language and focused on modeling cross-organizational business processes.

Participants of collaborative business processes consist of multiple business entities or roles which agree to join the collaboration and interact with each other during the execution of business processes. Usually, an enterprise's business processes and services are operated in the enterprise domain and open only to authorized employees and customers. Therefore, each enterprise domain has its security infrastructure to protect information assets and grant users proper rights to access services under the condition that user's operations comply with the policies defined for the user's role in business processes. In order to support business collaborations between enterprises, security domains of participating enterprises must be configured properly to grant their partners the access to their services and by doing so satisfy the requirements of business processes and yet protect information assets from unauthorized access by third parties. Therefore, assurance of trustworthy and secure access to services across enterprise domains is a must prerequisite for effect and secure deployment and operation of business collaborations.

Usually, each enterprise domain in the collaboration has to take responsibility for analyzing security requirements, defining proper policies, and enforcing them in their systems. Such kind of manual procedures must be iterated if an enterprise has participations of a number of business collaborations and those collaborations dynamically change from time being, e.g. created on demand and dissolved after business has been completed or contracts expire. This makes security management tasks complicated, effort intensive, error-prone, and inconsistent. E.g. security policies defined in different domains might contradict each other or lose synchronization due to unexpected policy updates in one of the domains. Therefore, it makes sense to develop a method which automates or semi-automates security management of complex and dynamic business collaborations to ensure precise and can-be-verified security policies to be enforced in the processes. This paper is focused on identification and establishment of trust between enterprises in business collaborations. Identifying trust relationships of business collaborations provides a basis for defining global security requirements of the collaboration and then translating them to specific security requirements or policies which can be deployed and enforced in individual partners' domains. The main contribution of this study is the algorithms to extract trust relationships from formally described collaborative business process models to generate specific trust policies for participating enterprise domains. This method is scalable for handling complex business collaborations and provides automation for enforcing trust policies with support of a deployment infrastructure.

The rest of the paper is organized as follows. Section 2 introduces readers to business process modeling and modeling languages and illustrates how a business collaboration is modeled. Section 3 analyzes security requirements for execution of business collaborations across enterprise domains. Section 4 presents state-of-the-art technologies for federating trust relationships and discusses some related research in generating security requirements from business process models. Section 5 presents our main contribution for deriving trust federation from collaborative business process models. Derivation of trust federation from WS-CDL and BPMN models is also illustrated in this section. Section 6 is about deployment processes of the trust federation for enterprises which participate in collaboration. Section 7 discusses use cases of the approach presented in this paper and envisions potential applications in securing applications in Internet of Services and cloud computing. Finally, Section 8 closes the paper with conclusions.

2 Modeling business collaborations

This section introduces basic concepts of business process modeling and presents various modeling languages which can be applied to model business collaborations. Then, one scenario in automotive industry is presented to illustrate how business collaboration is described as business processes.

2.1 Overview of business process modeling

Business Process Modeling (BPM) is a fundamental concept in engineering and research fields of business process management. A prominent feature of business process modeling is to create high level, domain specific models or abstractions rather than focus on platform specific models which often involve details and dependencies of implementation and execution environments. BPM is also considered to be a key driving force in building, maintaining, and evolving enterprise applications and an agile software development technology which interprets business strategies into IT executions in a fast and standardized way (Becker et al. 2003). Business process modeling has been an important instrument of model-driven approach to define collaborative business processes which interconnect enterprise systems of different participants. This cross-organizational characteristic is reflected by the term "Service Choreography" while "Service Orchestration" is focused on collaboration of services as steps defined by a business process (e.g. composition of services) within an enterprise. From a global point of view, service choreography is a more

collaborative way to define interactions between enterprise systems owned by multiple parties and focused more on visible behaviors and message exchanges between participants. In this sense, collaborative business processes can be seen as “composition of processes” offered by different providers for provisioning value-added services or for a commonly agreed business goal.

2.2 Business process modeling languages

A number of BPM languages are currently available from industrial standard organizations such as OMG, W3C, OASIS, and WfMC. Important players such as ARIS (Scheer 1998), BPDm (OMG-BPDm 2008), ebXML (UN/CEFACT and OASIS 2001), BPEL, BPMN, BPMN2, WS-CDL offer capabilities to describe collaborative business processes. Some representative modeling languages are listed as follows.

WS-BPEL (Web Services Business Process Execution Language): WS-BPEL is a fusion of Web Service Flow Language developed by IBM and XLang developed by Microsoft (Alves et al. 2007). WS-BPEL is an XML based flow language which is used to formally define business process activities and business interaction protocols. BPEL is well known as a classic service orchestration instrument which focuses on execution aspect of a private workflow inside enterprises. However, WS-BPEL also offers abstract processes to define behaviors and interfaces exposed by business partners in an overall collaboration process without need of revealing internal flows. In this sense, service choreography can also be supported by using WS-BPEL though abstract business processes are considered non-executable if input of internal process details is missing (Papazoglou and Dubray 2004; Roser and Bauer 2005).

BPMN (Business Process Modeling Notation) specification is an OMG standard (OMG 2008, 2009). BPMN is intended to offer a notation which is understandable to all levels of users ranging from analysts who model processes from a strategic view, to technical developers who implement the technology to materialize the processes, and to business people who manage and monitor the execution of those processes. BPMN is a flowcharting based technique which defines business process diagrams (BPD) to model business operations by using visual components and flow controls. BPMN can be used to model private business processes within an enterprise and model public business processes in collaborative environments. BPMN supports collaborative business modeling by providing “Pools” to separate participant processes.

BPMN 2 specification enhanced BPMN 1.1 with exchangeable format to support multiple modeling tools, BPMN choreography modeling, and formalization of execution semantics, etc. BPMN choreography defines

business contracts and messages exchanged among multiple partners and describes how a business contract is enforced into individual behavior of partners.

WS-CDL (Web Service Choreography Description Language) is an XML-based language developed by W3C Web Services Choreography Working Group (Kavantzas et al. 2005). WS-CDL describes peer-to-peer collaborations of parties from a global viewpoint by defining their common and complementary observable behavior. Similar to abstract BPEL processes, WS-CDL is focused on defining interactions of participants and protocols of message exchanges among them. In contrast to a business process execution language, WS-CDL can be used to model interoperable processes in collaboration without taking into account platforms or programming model dependent issues for implementation and execution in hosting environments. WS-CDL choreography models are also intended to be used to generate code skeletons for implementing web services or BPEL abstract processes (Barros et al. 2005).

2.3 Collaborative processes in automotive design

To illustrate business collaboration, we present an exemplary business process which describes a car seat design in the context of the eco-calculation scenario of TEXO Services (Theseus Programm 2009). TEXO is a use case of the Theseus research program with the aim for creating an IT infrastructure to support tradable business services on the Internet of Services. The eco-calculator is the core scenario of TEXO which demonstrates the lifecycle of tradable services from service invention to service engineering, to service matchmaking, to service runtime, and to service consumption. The story line is about a certified calculation service which is offered in Internet of Services to provide eco-value calculation capability which helps car makers ensure their automotive parts in compliance with ecological directives of Australia and hence be able to obtain the permission to sell automotive products in Australian market.

The BPMN diagram in Fig. 1 depicts a car seat design process. In automotive industry, car makers often reply on component suppliers to provide car seats and outsource car seat design to a car seat manufacturer. Since the car seats are to be assembled in the car models for Australian market, the design of the car seats must meet Australian eco-directives before manufactured cars are allowed to enter Australian market. The car seat manufacturer does not possess expertise for material analysis or eco-assessment. She or he has to rely on an engineering partner who can do the work, i.e. analyzing physical and chemical composition of materials used in manufacturing car seats. In order to guarantee footprint of manufacturing a car seat in compliance with the eco-directives, the engineering partner needs a specialized service which calculates eco-value of the car seat

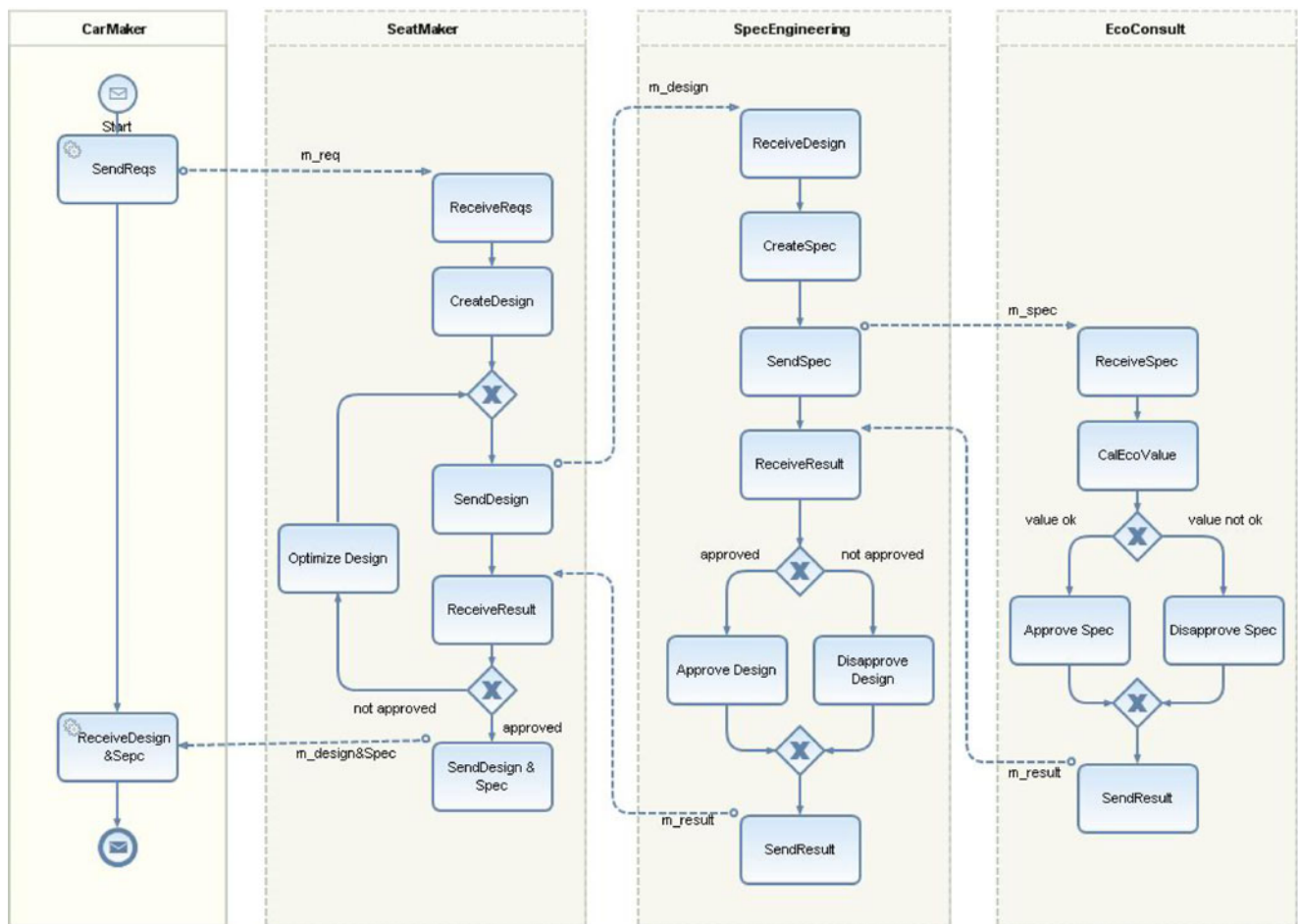


Fig. 1 Business process of a collaborative car seat design

and check if the result is acceptable accord to Australian eco-directives. E.g. regulations like “at least 85% materials must be recyclable” or “Carbon footprint for making a seat must be less than 5 kg”. If the design complies with all regulations, the car marker will receive an eco-compliance certificate. For other cases the car seat design process has to be iterated until the calculated result is acceptable. The car seat design scenario involves four business entities.

- 1) A car maker which sends car seat requirements and outsources car seat manufacturing to a car seat manufacturer.
- 2) The car seat manufacturer which creates the seat design and supplies car seats to the car maker.
- 3) A specification engineering company which generates technical specifications from the seat design delivered by the car seat manufacturer.
- 4) An Eco-consulting company which offers a certified eco-calculation service.

Business collaboration can be modeled using various modeling languages. Section 5 presents concrete descrip-

tions of the car seat design as a WS-CDL model and as a BPMN model respectively. We will use this scenario in the rest of the paper as a reference business process to demonstrate how trust relationships can be derived from formally described business processes.

3 Security requirements of business collaborations

Table 1 shows multi-layered security requirements in the enterprise computing landscape. Security on the network layer, system layer, and data layer is usually addressed by an enterprise’s internal security systems. However, security for business collaborations is mainly focused on the application layer where interfaces for business partners must be made available. Security configurations on the application layer must be consistent and compliant with defined business processes and in coordination with their business partners.

Security related requirements on the application layer consist of authentication, authorization, privacy, etc. When a collaboration is established between two partners, the

Table 1 Multi-layered security of the enterprise computing landscape

Application layer	Authentication
	Authorization
	Privacy
Data layer	Data encryption
	Data backup and recovery
	Auditing
System layer	System hardening
	Antivirus protection
	Host intrusion detection
Network layer	Firewalls
	Network intrusion detection

access to a partner's services or resources must be authenticated, that is, requests to the service must be proven coming from a valid user whose identity can be verified against the user database at the service provider side. As each partner in the business collaboration maintains user identities or user database for its own domain, it must be enabled to verify and trust the identities of those requests coming from the outside of its enterprise domain. Therefore, identity or trust policies must be for each partner domain available to provide rules about how user identities from partner domains can be verified and authenticated according to requirements of business processes.

Authorization is the next step after a user's identity is successfully verified. It deals with the “who-what-when” question, that is, who (user) can access what (resources) and when (conditions). The service provider in business collaboration needs to define a set of rules (authorization policies) which regulates how and under what condition services or resources are offered for their partners. Therefore, each enterprise domain in the business collaboration has to manage access rights of their users and for their partners in case that business collaboration must be supported. Privacy can be achieved by enforcing encryption on the communication level such as SSL or encryption on messages such as XML-encryption in SOAP messages for data exchange between partners (Nadalin et al. 2004). This paper is focused on the authentication (trust) aspect of cross-organizational business collaborations since establishment of identities and trust in the collaboration is a prerequisite of authorization and encryption.

In order to make services accessible across enterprise domains in a secure and usability-friendly manner, federation of user identities is required for enabling inter-enterprise single sign-on, meaning that a user in an enterprise domain is able to authenticate to a partner domain without need for an extra account and authentication. Currently, there are a number of available technologies which address cross-domain single sign-on for web applications and web services. E.g. SAML defines protocols to support identity

federation for HTTP based web applications in different domain (Godik and Moses 2003). WS-Federation specification (Bajaj et al. 2003) provides mechanisms to broker trust of identities and authentication for accessing web services in partner domains. Similar concepts can be found in Liberty Alliance (Liberty Alliance 2009), Shebbloth (Shibboleth 2009), etc. However, mechanisms to analyze and identify federation requirements which reflect business requirements of dynamic collaborations are rarely covered. Derivation of trust policies from business process definitions can effectively help in filling current research gap.

4 Related work

This section introduces available technologies which deal with user identities and authentication in enterprise applications and cross-enterprise business processes. Related work on deriving security requirements from business process definitions is also discussed.

4.1 Enterprise single sign-on

In an enterprise domain, applications and services reply on a user database, such as LDAP (Sermersheim 2006) or Active Directory (Microsoft 2009), to authenticate users and manage their access rights. Information in the user database includes user reference data and authentication data such as their passwords, certificates, roles, and access rights. The main focus of the enterprise SSO is to seamlessly broker authentication for divers systems such as windows domain authentication, SAP/R3 systems as well as enterprise portals etc. Enterprise SSO is a relatively mature technical field and many industrial products are available in the market, for example, major software vendors such as IBM, SAP, and SUN are providing various SSO solutions including IBM Tivoli Access Manager (IBM 2009), SAP log-on tickets (Hirao et al. 2008), and Sun security access manager (Sun 2009).

4.2 Cross-domain single sign-on

New service paradigms such as Internet of Services (Heuser et al. 2008) and cloud computing provide new models for service provisioning on the internet or in the cloud to support cross-enterprise (domain) business processes. An enterprise cannot only reply on its own identity management system to authenticate requests for its services. It must be enabled to authenticate requests initiated by its partners. Although industry has not made trust federation generating technologies for business processes available, there are a number of emerging technologies which address implementation aspects of user identity federation and authentication brokerage.

OpenID is an open, decentralized standard for user authentication by which users can use a single identity for logging on to different web services (including services which across multiple domains) (OpenID Foundation 2009). OpenID removes the need that end users have to present their account and password for authenticating to each service because identity providers which issue identifiers to end users are trusted by relying parties (service providers). OpenID has gained its popularity: Identity providers are available from many big internet providers such as AOL, Google, IBM, Microsoft, etc.

SAML is an OASIS standard which allows enterprises to establish trust relationships with their business partners or customers. It is used for exchanging authentication and authorization data between different security domains (Godik and Moses 2003). SAML 2 extended the SAML 1.1 standard with contributions from Liberty Identity Federation Framework (ID-FF) developed by Liberty Alliance (Liberty Alliance 2009). ID-FF proposed a standardized, cross-domain, web-based, single sign-on framework. In the SAML standard, “identity provider” is an authentication authority where users are registered. The identity provider offers users authentication service and issues them SAML assertions (tokens) which are trusted and can be verified by service providers. SAML defines security assertions, a set of protocols for integrating assertions in service requests and responses as well as bindings which encapsulate SAML messages into HTTP or SOAP messages. Two main applications of SAML are web single sign-on and federated identity in B2C and B2B scenarios.

WS-Security and WS-Federation WS-Security (Web Services Security) is a federated identity specification which provides capabilities to encapsulate security within SOAP messages (Nadalin et al. 2004). WS-Security defines attributes which can be added to a SOAP message header for user authentication and message confidentiality and integrity. WS-Security presents authentication information as tokens embedded in SOAP headers and supports tokens like Kerberos tickets, X.509 certificates, and SAML assertions. WS-Federation (Bajaj et al. 2003) was developed by BEA, IBM, Microsoft, Verisign etc. It extended WS-Security and Security Token Service (STS) model defined in WS-Trust (Nadalin et al. 2007) to support scenarios where resources managed in a security domain can be provided to security principals whose identities and attributes are managed in other domains. WS-Federation provides mechanisms for identity brokering, attribute discovery and retrieval, authentication and authorization claims between federation partners across organizational boundaries. WS-Federation is aimed for providing a common infrastructure to perform federated identity operations for web services and browser-based applications.

4.3 Related research on security requirements of business processes

There are a few research activities which address security requirements for business processes including processes across enterprise domains. Wolter et al. (2009) developed a model-driven business process security requirement specification which introduces security annotations into business process definition models for expressing security requirements for tasks in business processes. Security annotations can be later on transformed into deployable authorization policies such as XACML or AXIS 2 security configurations. Similar work can be found in (Felkenr and Kruk 2007). Robinson et al. (2006) developed an approach to compile business process choreography (WS-CDL processes in this case) into enhanced authorization policies. In doing so, a minimal set of authorizations required for business collaboration is automatically derived. Those deployable authorization policies can be enabled and disabled in a just-in-time manner to match the control flow defined by the choreography. Compared with our approach, the above mentioned research work went into the similar directions, that is, automating security requirement design by analyzing business process models. However, those related activities were set up with an assumption that valid user identities have been established before authorization policies can be enforced. Their main focus is on the access control aspect of business processes rather than authentication requirements.

5 Deriving trust federation from collaborative business processes

This section presents the core idea for deriving trust federation from collaborative business processes. Concrete algorithms to handle business collaborations modeled by WS-CDL and BPMN processes are described respectively in Section 5.1 and Section 5.2.

In the model-driven engineering context, collaborative business processes are available as non-executable models. By mapping such kind of high level processes into executable business processes such as BPEL and other low-level models, business processes become deployable and executable. As those model may specify business (abstract) roles in a collaboration rather than specific business entities, one precondition for the mapping to be workable is that concrete business entities must be identified and assigned with corresponding business roles and the interfaces to offered services, e.g. web service description documents, such as WSDL, must be available. Trust federation generated from business process models may need a further step to map roles to concrete business entities. With a policy infrastructure in place, requirements

for trust federation can be expressed as trust policy and deployed in corresponding participating domains.

The idea to derive trust federation from business processes is to parse model description documents, extract information about interactions or data flows between business entities or roles. By analyzing business relationships between each pair of business partners, we can derive basic requirements for establishing trust federation and makes collaboration execution possible. If we look back to the car seat design scenario in Section 2, it is intuitive to see that services offered by different partners must be configured in such a way that requests from other partners are permitted only if they comply with business requirements defined in the model. Therefore, three trust realms or cycles of trust (meaning that two parties in a realm or cycle trust each other) need to be configured for execution of the collaboration. As shown in Fig. 2, the trust federation includes:

- 1) R1: Trust realm between the Car Maker and Seat Maker domains
- 2) R2: Trust realm between the Seat Maker and Spec Engineering domains
- 3) R3: Trust realm between the Spec Engineering service and EcoConsult domains

In WS-CDL business process models, there are particular sections where service choreography and relationships among business roles are defined. Therefore, it is relatively straightforward to read out those pieces of information from business process definitions and extract needed interaction information for identifying trust relationships. Compared with WS-CDL models, explicit expression of relationships between partners in BPMN models may not be available because BPMN only defines graphic notation to describe business processes and its metamodel is vendor-specific. We may have to examine all interactions and message blocks in the models to extract trust relationships.

5.1 Derivation algorithm for WS-CDL business process models

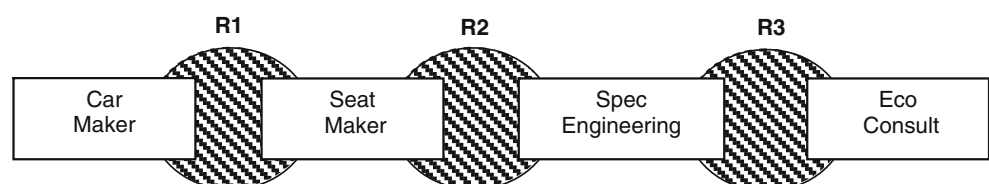
Before we dig into the algorithm for deriving trust federation from WS-CDL models, the WS-CDL specification and its building blocks are briefly introduced.

A) Overview of WS-CDL

In WS-CDL (Kavantzas et al. 2005) specification, a package is a container of one or more than one choreography. It also includes some information which is shared by all choreographies in a package. Information such as role type, participant type, relationship type, and channel type is defined in a package and reflects how a participant couples with other collaborating partners in a choreography. A role type describes observable behaviors a participant expose in order to collaborate with others. E.g. the “Consumer” role type is connected to the consuming of goods or services and the “Provider” role type is connected with the provisioning of goods or services. A relationship type specifies a subset of behaviors of roles, which is involved in the relationship between two participants. A participant type represents logical groupings of roles. A channel realizes a point of collaboration between participantTypes and defines the way how participants exchange information. Besides the above information a package may contain some other global information such as information type, token, and import.

A choreography contained in a package defines a collection of activities such as control-flow, workunit and basic activities that may be performed by one or more of parties. Activities like sequence, parallel, choice, and workunit allow constructing basic control-flows of tasks and basic activities define actions performed by the parties in a choreography. A sequence activity defines those activities which are supposed to be executed in sequential order. A parallel activity defines those activities which are executed at the same time. A choice activity defines that one of two or more activities can be selected and executed. A workunit describes conditional or repeated execution of an activity. Basic activities include interaction, noaction, assign, and perform. Noaction describes no action will be performed at some point in a choreography. The Assign activity is used to transfer the value of one variable to another variable within one role. The Perform means a complete and separately defined choreography is executed. The most important and frequently occurred action is an interaction. Interactions describe an exchange of information between parties. Interactions can have one of three purposes: to make a request, or to make a response, or to make a request that requires a response.

Fig. 2 Trust federation for the car seat design



B) Modeling Business Collaboration with WS-CDL

The car seat design scenario in Section 2 can be modeled as a choreography using WS-CDL. The following shows some excerpts of the car seat design model.

```
<package name= "CarSeatDesign" xmlns= ..." >
  <roleType name="CarMaker">
  </roleType>

  <roleType name="SeatMaker">
  </roleType>

  <roleType name="SpecEngineering">
  </roleType>

  <roleType name="EcoConsult">
  </roleType>

  <relationshipType name="CarMaker-SeatMaker">
    <roleType typeref="tns: CarMaker"/>
    <roleType typeref="tns: SeatMaker"/>
  </relationshipType>

  <relationshipType name="SeatMaker-Engineer">
    <roleType typeref="tns: SeatMaker"/>
    <roleType typeref="tns: SpecEngineering"/>
  </relationshipType>

  <relationshipType name="Engineer-EcoConsult">
    <roleType typeref="tns: SpecEngineering"/>
    <roleType typeref="tns: EcoConsult"/>
  </relationshipType >

  . . .

  <participantType name="PerfectSeat">
    <role type="SeatMaker"/>
  </participantType>

  <choreography name="CarSeatDesign" root="true">
    <relationship type="CarMaker-SeatMaker"/>
    <relationship type="SeatMaker-Engineer"/>
    <relationship type="Engineer-EcoConsult"/>

    <sequence>
      <interaction name="Requirements" operation="Requirements">
        <participate relationshipType="CarMaker-SeatMaker"
          fromRoleTypeRef="CarMaker" toRoleTypeRef="SeatMaker"/>
        <exchange name="Requirements" action="request"
          informationType="RequirementsType">
          </exchange>
        </interaction>

        . . .

        <interaction name="EcoCal" operation="EcoCal">
          <participate relationshipType="Engineer-EcoConsult"
            fromRoleTypeRef="SpecEngineering"
            toRoleTypeRef="EcoConsult"/>
          <exchange> . . . </exchange>
        </interaction>

        . . .

        <interaction name="SendDesignAndCert"
          operation="SendDesignAndcert">
          <participate relationshipType="SeatMaker-CarMaker"
            fromRoleTypeRef="SeatMaker" toRoleTypeRef="CarMaker"/>
          <exchange> . . . </exchange>
        </interaction>

      </sequence>
    </choreography>
  </package>
```


In this business process model, a choreography section called CarSeatDesign defines a number of activity flows in the business process as well as data exchange between partners. E.g. the interaction for calculating eco-values as well as the messages defined by informationType in the exchange element can be found in the above model. In the Package section, roles, relationships, and participants involved in the business process are defined prior to the choreography section. Participants can be assigned one or more than one role in the collaboration. If participants are not available in the model, a mapping from roles to business entities is required to materialize the generated trust federation.

C) Derivation Algorithm for WS-CDL Business Process Models

The algorithm needs the following information artifacts before trust relationships between partners can be derived:

- 1) Information about participants: Who the participants are in case of no participants specified in the model and where to find concrete business entity data, such as unique identifiers, names, and contacts.

- 2) Information about capabilities: What services those participants can provide and how to access the services technically. E.g. URIs of services or URLs to their WSDL (Web Service Description Language) documents should be made available for process execution.

Hence, a discovery and matching infrastructure must be available for retrieval of the above required information. In fact, we have developed a management system which maps business roles of a WS-CDL model to concrete business entities by matching the capabilities defined in the model with the services published in a public registry. The detailed matching procedure is described below.

- 1) Potential participants (candidates) publish their business entity data and service offers in a service registry.
- 2) Appropriate participants are selected based on their service offers and the desired capabilities specified in the model.
- 3) The business process model (a WS-CDL document) is distributed to participants after they accept the invitation and agree to join the collaboration.

Then, the following algorithm (in pseudo-code) is applied in deriving trust relationships from the WS-CDL model.

```

1. Identify roles a participant  $P_i$  ( $1 \leq i \leq n$ ) is committed to play and save them in list  $RO_i$ . (A participant can play multiple roles)

2. For elements  $R_j$  ( $1 \leq j \leq m$ ) of the type <relationshipType> in the WS-CDL model do:
    a. Analyze the two subelements <roleType> (each roleType has one typeref attribute):
    b. For participants  $P_i$  do:
        If a value "V" of one typeref attribute is  $\in RO_i$  store a value "W" of the other attribute in a list  $I_{P_i}$  of interacting partners from  $P_i$ .

3. For participants  $P_i$ , map the role names of the participants in the list  $I_{P_i}$  to the names of actual organizations.

4. For participants  $P_i$ , eliminate duplicates in  $I_{P_i}$ . Thus, for each partner  $P_i$ ,  $I_{P_i}$  includes all organizations which interact with  $P_i$ .

5. Enable trust relationships between  $P_i$  and its all partners which interact with  $P_i$ .

```

The above algorithm assumes that bidirectional trust must be available for each interaction. In case of deriving unidirectional trust relationships, e.g. only requests or responses are permitted, Step 2.b. should be revised as

```

2.b. For all participants  $P_i$  do:
    If the value V of one typeref attribute is  $\in RO_i$  store the value "W" of the other attribute in the list  $I_{P_i}$  of interacting partners ONLY if there is a match from V and W with the two attributes <ToRoleTypeRef>, <FromRoleTypeRef> in the subelement <participate> of an the corresponding <interaction> element in the <choreography> section of the WS-CDL.

```

5.2 Derivation algorithm for BPMN business process models

The algorithm for deriving trust federation from BPMN models is slightly different because BPMN is a specification for diagrams rather than an XML-based description language. This section explains differences between a BPMN model and a WS-CDL model and presents an adapted derivation algorithm for business processes modeled by the STP/BPMN modeler (STP 2009).

A) Modeling Business Collaboration with BPMN

BPMN supports collaborative business process diagrams. E.g. the Pool element in BPMN can be used as a container to separate the process of a participant from processes of the rest parties in collaboration (see Fig. 1). BPMN has two major

differences from WS-CDL business process models:

- (1) The BPMN notation is standard but the syntax of BPMN models is tool dependent. In order to transform BPMN diagrams to model descriptions, we have to rely on a specific BPMN tool.
- (2) There are no relationships between business roles/entities, which are explicitly stated in the model. Therefore, interactions defined in the BPMN model must be examined.

In our work, an Eclipse tool called STP/BPMN modeler is chosen as a reference BPMN tool (STP 2009). This modeler uses XML Metadata Interchange (XMI) as the storage format for BPMN models (OMG 2007). The following is the excerpts of the XMI document of the car seat design business process (in Fig. 1).

```
<?xml version="1.0" encoding="UTF-8"?>
<bpmn:BpmnDiagram xmi:id="_carseatdiagram">

  <pools xmi:type="bpmn:Pool"
xmi:id="_idcarmaker" name="CarMaker">

    <vertices xmi:type="bpmn:Activity" xmi:id="_idsendreqs" name="SendReqs"
activityType="Task">
      <outgoingMessages href="#_idmess1"/>
    </vertices>
    .
    .
    .
    <vertices xmi:type="bpmn:Activity" xmi:id="_idreceivedesignspec"
name="ReceiveDesign&Spec">
      <incomingMessages href="#_idmess6"/>
    </vertices>
  </pools>

  <pools xmi:type="bpmn:Pool" xmi:id="_idseatmaker" name="SeatMaker">
    .
    .
    .
  </pools>

  <pools xmi:type="bpmn:Pool" xmi:id="_idspecengineering"
name="SpecEngineering">
    .
    .
    .
  </pools>

  <pools xmi:type="bpmn:Pool" xmi:id="_idecoconsult" name="EcoConsult">
    .
    .
    .
  </pools>

  <messages xmi:id="_idmess3" source="_idsendspec"
target="_idreceivespe"/>

  <messages xmi:id="_idmess4" source="_idsendresulteco"
target="_idreceivresultspec"/>

  <messages xmi:id="_idmess5" source="_idsendresultspec"
target="_idreceivresultdesign"/>

  <messages xmi:id="_idmess2" source="_idsenddesign"
target="_idreceivedesign"/>

  <messages xmi:id="_idmess6" source="_idsenddesignspec"
target="_idreceivedesignspec"/>

  <messages xmi:id="_idmess1" source="_idsendreqs"
target="_idreceivereqs"/>

</bpmn:BpmnDiagram>
```

In the XMI model, a Pools section contains the activities of a participant's process. An activity element has references to inbound or/and outbound messages it receives from or sends to other activities. Those messages are defined independently from the pools and consist of source and target activities.

B) Algorithm for Deriving Trust Federation from BPMN Models

The deriving algorithm for WS-CDL models in Section 5.1 can be adapted to derive trust federation from BPMN process models. The message elements in the bottom part of a BPMN business process contain a pair of source and target tasks which represent the sender and recipient of a message respectively. Since each message is referenced by some activities of a pool. The algorithm examines messages one by one and checks if the source and destination tasks belong to difference Pools. When a cross-pool message is identified, it indicates that there is an interaction between two business participants. After all messages in the model have been examined, the rest steps are similar to the algorithm for WS-CDL models. Trust relationships between a business participant and each of its partners can be identified and further processed depending on if unidirectional trust or bidirectional trust is required.

6 Deployment of trust federation

This section discusses the materialization of trust federations derived from collaborative business processes, discovery of business entities and service offers, as well as policy deployment.

As mentioned in Sections 5.1, business process models usually define participants in an abstract way, meaning only names of companies and name of their service offers are specified. It also might happen in WS-CDL business processes only business roles are specified and concrete business participants are to be decided. Therefore, additional information about the concrete business entities joining the collaboration and the materialized description of their services must be available before the trust federation can be deployed into participants' system domains.

The business entity data and service description are available from a registry which can be implemented using UDDI (Universal Description Discovery Integration) (Clement et al. 2004). UDDI provides an open registry which enables businesses to publish their service listings and consumers to discover service offers. UDDI defines a business key as a unique identifier for a business entity and the metadata for describing business entities and their service offers. Identifiers, function descriptions, access points, and bindings of services are listed to provide technical accessibility. The follow is an exemplary business entity (PerfectSeat) and its service published in a UDDI repository.

```
<businessEntity businessKey="cb855aa0-5dd4-11d5-80dc-110044117b46"
  operator="www.businesscollaboration.com/services/uddi">

  <discoveryURLs>
    <discoveryURL useType="businessEntity">
      http://www.business collaboration.com/services/uddi
      /uddiget?businessKey= cb855aa0-5dd4-11d5-80dc-110044117b46
    </discoveryURL>
  </discoveryURLs>

  <name>PerfectSeat</name>

  <description xml:lang="en">A cart seat supplier</description>

  <contacts>
    <contact useType="support">
      .
      .
      .
    </contact>
  </contacts>

  <businessServices>
    <businessService serviceKey="c5921160-3e16-11d5-98bf-002035229c64"
      businessKey="cb111bb2-4cc5-aa05-cd09-eb11640098a6">
      <name>Send design</name>
      <description xml:lang="en">Send back car seat design documents
      </description>
      <bindingTemplates>
        <bindingTemplate bindingKey="d594a970-3e16-11d5-98bf-002035229c64"
          serviceKey="cb111bb2-4cc5-aa05-cd09-eb11640098a6">
          <description xml:lang="en">SOAP binding for Sending documents
          </description>
          <accessPoint URLType="http">
            http://services.perfectSeat.com:8080/soap/<accessPoint>
            .
            .
            .
          </bindingTemplate>
        </bindingTemplates>
      </businessService>
    </businessServices>
  </businessEntity>
```

After the trust federation with concrete business and technical information are available, we can create vendor specific trust policies and enforce them in participants' systems through a policy deployment infrastructure. Those trust policies specify how identities and attributes can be shared between participants according to established trust relationships. In the WS-Security and WS-Federation framework, trust policies can be expressed in the format of WS-Policy (Bajaj et al. 2006a, b) and deployed on the Security Token Service (STS) (Nadalin et al. 2007) in the participant domains. Trust information such as attributes and certificates of business entities can be stored in the UDDI registry. Thus, the STS of a participant can obtain appropriate trust data from the registry for authenticating requests from his/her partners according to the policies he/she receives for enabling the federation. Trust federation can also be directly deployed as security configurations depending on the applied federation techniques. E.g. OpenSSO is an open source identity federation solution which supports SAML or WS-Federation tokens for cross-domain single sign-on (SUN 2009). The trust federation derived from business process models can be mapped to the configurations of "cycles of trust" and enforced at the OpenSSO instances running in participants' domains.

7 Discussions

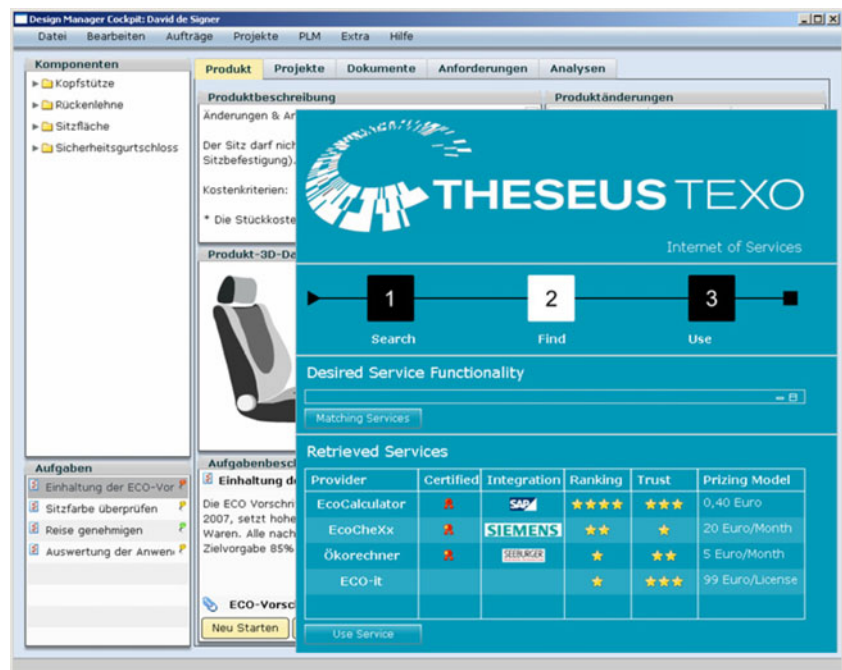
The approach presented in this paper can be generally applied in deriving trust federation for secure execution of cross-enterprise business processes in agile and

dynamic collaborations. The derivation algorithms can be adapted to handle business processes described by other modeling languages than BPMN and WS-CDL as long as interactions between partners are explicitly or implicitly available from the model description. This section will present two use cases and a vision of its future applications.

7.1 Eco-calculator service

The car seat design business process mentioned in Section 2.3 is one application of the TEXO platform (Theseus Programm 2009). The main focus of the platform is to offer value-added services developed by small and medium sized enterprises (SME). SMEs such as those in Germany usually specialize in a specific field where they are capable of innovating and responding to market needs quickly. Leveraging the TEXO platform, SMEs can open market opportunities and offer services to a large number of customers without being distracted from their core expertise business by investing and maintaining their own infrastructure. On the consumption side, organizations can search for services which directly meet their needs and integrate them into their client applications. The need of consumers can be also satisfied by combining services from different providers through subcontracting or brokerage. One of the TEXO scenarios is the eco-calculator service described in Section 2.3. Figure 3 shows a screenshot of the software user interface of a service consumer who searches for eco-calculator services for the car seat component in the TEXO service marketplace.

Fig. 3 TEXO eco-calculator service



Once finding out a best-fit service from many available offers in the marketplace, the chosen service will be delivered and integrated to the service consumer's runtime environment by a TEXO service delivery platform following some procedures such as contracting or subscription and payment. There are several business processes happening at different stakeholders. In the backgrounds, however, some other roles are also involved in the lifecycle, such as service innovators who monitor service usages and customer needs to improve service provision, service developers who implement services for service providers, and a service community which provides ratings of services, etc. In such a complex but systematically organized service ecosystem, federated trust among stakeholders and participants as well as interoperable, manageable security configurations in each domain together with monitoring and fraud detection are vitally important to secure interests of all parties. Using model driven approach to formalize complex business collaborations and derive trust federation provides a convenient and manageable means to support fast and reliable implementation of identity management, authentication and authorization, and in large extent to minimize risk of human errors and guarantee compliance with business design.

7.2 Discrete manufacturing

In enterprise application environments, there is a need that different Supplier Chain Management (SCM) systems collaborate with each other. This kind of business model is especially attractive to small and medium businesses as it allows fast participation in changing and dynamic collaborative business processes.

In the scenario of discrete manufacturing, various component suppliers are required to interlink their SCM systems and make interoperation with each other possible. Figure 4 shows a business collaboration in discrete manufacturing, where component/material suppliers at three levels sign a contract to collaborate and provide semi-finished products to a final manufacturer. The hierarchical relationship among subcontractors or component providers in the collaboration can be modeled with WS-CDL or BPMN. Basic interactions and relationships described in the model can then be used to derive trust relationships between different enterprise domains and used as input to authentication and authorization implementation at the side of each participating party. In this case, six trust realms between providers are identified (highlighted by dotted circles).

7.3 Visions of future applications

We envision that derivation of trust federation for collaborative business processes can contribute to building

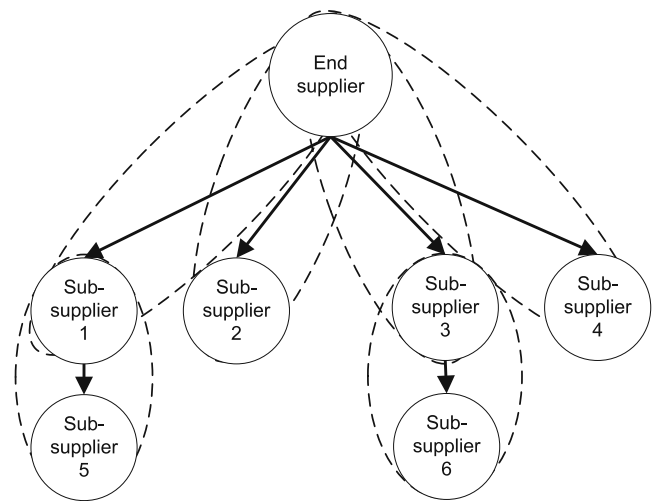


Fig. 4 Trust federation of the discrete manufacturing scenario

security and trust for emerging computing paradigms such as Internet of Services and cloud computing.

Internet of Services creates a comprehensive service ecosystem resting on SOA, Web2.0, and Semantics as well as novel business models and user-driven innovation approaches for provisioning, searching, compositing, and value-adding of tradable services on the Internet (Heuser et al. 2008). Involvement of multiple parties such as service marketplaces, service providers, and service consumers indicates that trust must be established between participants and appropriate security configurations must be in place prior to the enactment of any execution of a business collaboration. Hence, this requires to look into the architecture of Internet of Services from a holistic point of view as well as those services and applications which make up the platform from specific perspectives to come up with reliable and error-free solutions (methods, services, and tools) to deal with security challenges and by doing so secure intellectual properties and business interests of all parties in Internet of Services.

The presented approach can be also applied to applications hosted on the cloud, such as Amazon's Elastic Compute Cloud (Amazon 2009) and Google's App Engine (Google 2009), where computing resources are provided as services in a pay-per-use manner in order to reduce TCO (Total Cost of Ownership) of service provisioning. Composition of services to support business collaboration on the cloud is exactly an application of the trust derivation approach we present in this paper. In addition, scaling applications and services across different clouds, that is, service composition on the cloud is also a compelling use case that shows how critical trust is for the applications on the clouds to support business requirements of their customers

8 Conclusions

This paper reviews process modeling technologies for implementing business collaboration, discusses security requirements for execution of business processes across enterprise boundaries, and presents an approach to derive trust federation from formally described business process models. The approach introduced in the paper enables effective mapping of high-level business interaction requirements to corresponding lower-level requirements for establishing trust relationships between business partners. It has been demonstrated to be applicable and feasible in support of trust management in service-centered computing environments. For example, it has been adopted and validated in a prototype software module for managing dynamic business collaborations in a virtual organization where a business service is provided to an end client by composition of services from different service providers. To establish trust configurations of the collaboration in a virtual organization, a business process model is defined to reflect business interactions by using a subset of the WS-CDL specification. After appropriate participants who are capable of playing the roles defined in the business processes are made available by a service discovery in a business service registry, necessary structure of trust federation can be algorithmically computed. The derivation can be conducted at design time as well as at runtime for supporting dynamic collaborations. With help of an infrastructure for materializing trust federation into deployable security policies, established trust relationships can be enforced in the security domains of the business participants.

Main advantages of deriving trust federation for business process models are summarized as follows.

Firstly, business process modeling languages such as BPMN and WS-CDL are designed to focus on business functions without explicitly addressing security and trust requirements of business processes. Computing trust relationships from business process model descriptions can effectively help business process designers capture necessary trust requirements for business collaborations.

Secondly, given formally described business process models, the decision on how trust federation is established is directly connected to the business decision of participating in a specific business process or business opportunity. Therefore, trust configurations can be updated just-in-time for reflecting dynamic changes of business requirements.

Thirdly, derivation of trust relationships based on business process models can help reduce overheads of security management and avoid errors and inconsistencies caused by manual effort.

Fourthly, the approach and algorithms presented in this paper are not limited in the scope of BPMN and WS-CDL models. Instead, this approach is adaptable and applicable for many other business modeling languages where interactions between participants in a business collaboration are explicitly or implicitly available.

Finally, in combination with a business service registry and policy deployment infrastructure, the approach for derivation of trust federation offers a semi-automated and verifiable means for managing trust in service-oriented application computing and can potentially contribute to trust establishment for the next generation of computing platforms such as Internet of Services and the clouds.

References

- Alves, A., Arkin, A., Askary, S., Barreto, Ch., Bloch, B., Curbera, Fr. et al. (2007). *Web services business process execution language version 2.0*. OASIS Standard. Retrieved 19 March 2009 from <http://docs.oasis-open.org/wsbpel/2.0/OS/wsbpel-v2.0-OS.html>.
- Amazon (2009). *Amazon elastic compute cloud*. Retrieved 19 March 2009 from <http://aws.amazon.com/ec2/>.
- Bajaj, S., Della-Libera, G., Dixon, B., Dusché, M., Hondo, M., Hur, M., et al. (2003). *Web services federation language (WS-Federation) version 1.0*. Retrieved 19 March 2009 from <http://msdn2.microsoft.com/en-us/library/ms951236.aspx>.
- Bajaj, S., Box, D., Chappell, D., Curbera, Fr., Daniels, G., Hallam-Baker, Ph. et al. (2006a). *Web services policy 1.2—framework (WS-Policy)*. W3C Member Submission. Retrieved 19 March 2009 from <http://www.w3.org/Submission/WS-Policy>.
- Bajaj, S., Box, D., Chappell, D., Curbera, Fr., Daniels, G., Hallam-Baker, Ph., et al. (2006b). *Web services policy 1.2—attachment (WS-PolicyAttachment)*. W3C Member Submission. Retrieved 19 March 2009 from <http://www.w3.org/Submission/WS-PolicyAttachment/>.
- Barros, A., Dumas, M., & Oaks, P. (2005). A critical overview of the web services choreography description language (WSCDL). *BPTrends Newsletter*, March 2005.
- Becker, J., Kugeler, M., & Rosemann, M. (Ed.) (2003). *Process management a guide for the design of business processes*. Springer-Verlag.
- Clement, L., Hatley, Q., Riegen, K., & Rogers, T. (Ed.) (2004). *UDDI version 3.0.2*. UDDI Spec Technical Committee Draft. Retrieved 19 March 2009 from http://www.uddi.org/pubs/uddi_v3.htm.
- Felkenr, A., & Kruk, T. (2007). *Modeling trust management and security of information*. ISSE/SECURE 2007 Securing Electronic Business Processes. Vieweg.
- Fielding, T., & Taylor, N. (2002). *Principled design of the modern web architecture*. ACM Transactions on Internet Technology (TOIT). 115–150. Association for Computing Machinery.
- Godik, O. S., & Moses, T. (Ed.) (2003). *OASIS standard security assertion markup language (SAML) v1.1*. Retrieved 19 March 2009 from <http://www.oasis-open.org/specs/index.php#wssv1.0>.
- Google (2009). *Google Apps*. Retrieved 19 March 2009 from <http://appengine.google.com/>.
- Heuser, L., Alsdorf, C., & Woods, D. (2008). *International research forum 2007* (pp. 100–101). New York: Evolved Technologist Press.

- Hirao, J., Choi, M., Cox, P., Passer, S., & Wun-Young, L. (Ed.) (2008). *SAP security configuration and deployment: The IT administrator's guide to best practices* (1st ed). Syngress.
- IBM (2009). *Tivoli access manager*. Retrieved 19 March 2009 from <http://www-01.ibm.com/software/tivoli/products/access-mgr-esso/>.
- Kavantzaz, N., Burdett, D., Ritzinger, G., Fletcher, F., Lafon, Y., & Barreto, Ch. (Ed.) (2005). *Web services choreography description language version 1.0*. W3C Candidate Recommendation 9. Retrieved 19 March 2009 from <http://www.w3.org/TR/ws-cdl-10/>.
- Liberty Alliance (2009). *Liberty alliance*. Retrieved 30 September 2009 from <http://www.projectliberty.org/>.
- Microsoft (2009). *Active directory*. Retrieved 19 March 2009 from <http://www.microsoft.com/windowsserver2003/technologies/directory/activedirectory/default.mspx>.
- Nadalin, A., Kaler, Ch., Hallam-Baker, P., & Monzillo, R. (Ed.) (2004). *Web services security v1.1*. OASIS Standard. Retrieved 19 March 2009 from <http://www.oasis-open.org/specs/index.php#wssv1.0>.
- Nadalin, A., Goodner, M., Gudgin, M., Barbir, A., & Granqvist, H. (2007). *WS-trust 1.3*. OASIS Standard. Retrieved 19 March 2009 from <http://docs.oasis-open.org/ws-sx/ws-trust/200512/ws-trust-1.3-os.html>.
- OMG (2007). *MOF 2.0/XMI mapping specification, V2.1.1*. Retrieved 19 March 2009 from <http://www.omg.org/technology/documents/formal/xmi.htm>.
- OMG (2008). *Business process model and notation (BPMN), version 1.1*. Retrieved 19 March 2009 from <http://www.omg.org/spec/BPMN/1.1>.
- OMG (2009). *Business process modeling notation (BPMN) version 1.2*. Retrieved 19 March 2009 from <http://www.omg.org/spec/BPMN/1.2>.
- OMG-BPDM (2008). *Business process definition metamodel*. Retrieved 19 March 2009 from <http://www.omg.org/spec/BPDM/1.0/>.
- OpenID Foundation (2009). *OpenID*. Retrieved 19 March 2009 from <http://openid.net/>.
- Papazoglou, M. P., & Dubray, J. (2004). *A survey of web service technologies*. Technical Report DIT-04-058, Informatica e Telecomunicazioni, University of Trento.
- Robinson, P., Kerschbaum, F., & Schaad, A. (2006). From business process choreography to authorization policies. In *Proceedings of the 20th Annual IFIP WG 11.3 Working Conference on Data and Applications Security* (pp. 297–309). Springer.
- Roser, S., & Bauer, B. (2005). A categorization of collaborative business process modeling techniques. In *Proceedings of Seventh IEEE International Conference E-Commerce Technology Workshops*.
- Scheer, A. (1998). *ARIS-Modellierungsmethoden, Metamodelle, Anwendungen*. Springer.
- Sermersheim, J. (Ed.) (2006). Lightweight directory access protocol (LDAP). *Request for comments: 4511*. Network Working Group. Retrieved 19 March 2009 from <http://www.ietf.org/rfc/rfc4511.txt>.
- Shibboleth (2009). *Shibboleth*. Retrieved 19 March 2009 from <http://shibboleth.internet2.edu/>.
- STP (2009). *STP/BPMN modeler*. Retrieved 19 March 2009 from <http://www.eclipse.org/bpmn/>.
- Sun (2009). *Sun OpenSSO enterprise*. Retrieved 30 September 2009 from http://www.sun.com/software/products/opensso_enterprise/index.xml.
- Theseus Programm (2009). *TEXO —business webs in the internet of services*. Retrieved 19 March 2009 from <http://theseus-programm.de/en-us/theseus-application-scenarios/texto/default.aspx>.
- UN/CEFACT & OASIS (2001). *ebXML business process specification, schema, version 1.01*. Retrieved 19 March 2009 from <http://www.ebxml.org/specs/ebBPSS.pdf>.
- Wolter, C., Menzel, M., Schaad, A., Miseldine, P., & Meinel, C. (2009). Model-driven business process security requirement specification. *Journal of Systems Architecture: the EUROMICRO Journal*, 211–223.

Dr. Ji Hu is a researcher at SAP Research Center Karlsruhe, Germany. He received a Ph.D. in Computer Science from the Hasso Plattner Institute, Germany. He has worked for several EU and national research projects including EU-Trustcom, Theseus/TEXO, and E-Mobility. His research interests include SOA, business processes, and various topics of IT security.